

The Penetration Testing Lifecycle

The phases

1. Pre-engagement (scope, RoE, kickoff)
2. Reconnaissance (passive -> active)
3. Scanning & Enumeration (ports, services, vulns)
4. Exploitation (gain initial access)
5. Post-exploitation (privesc, persistence, pivot, data)
6. Reporting (findings, severity, remediation)
7. Lessons learned & retest (close the loop)

Phase highlights

Recon: passive first (DNS, OSINT, Shodan, search engines) then active (scan). Passive = legal-ish, low noise; active = your RoE window.

Scanning: nmap host discover → port scan → service detection → NSE vuln scripts. Enumerate everything a service "tells" you.

Exploitation: match findings to exploits; verify impact. Professional exploitation is *proof of impact* with minimal damage.

Post-exploitation: privilege escalation (from rogue user to admin/root), lateral movement simulation, persistence proof, then collect "what would the attacker take" – but within RoE limits.

Reporting: every finding has repro steps, severity (CVSS), impact, and a fix. Executive summary for leadership, technical detail for devs.

Time allocation reality

Reporting is where professionals separate from hobbyists. A good report takes longer than the exploitation did.

Retesting

A retest verifies each finding is fixed. Professional courtesy: report the retest result per CVE ID, keeping history.

[← Engagement Types & Rules of ...](#)

[Reconnaissance: Passive & Acti...](#)